

SMART INDIA HACKATHON 2026



SMART INDIA
HACKATHON
2026

PRAMAAN

Secure Evidence Vault

Problem Statement ID – 26190

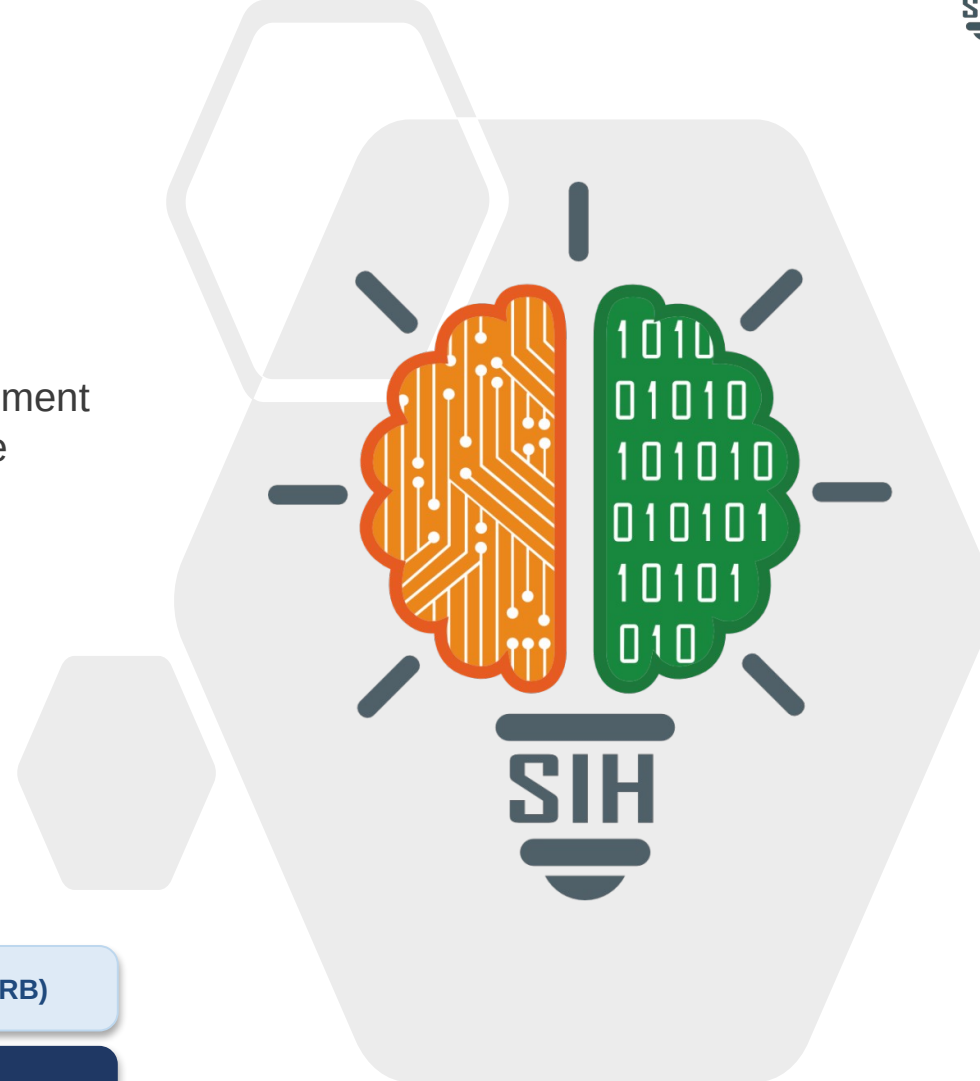
Problem Statement Title – Secure Digital Document Management System for law enforcement agencies, courts and investigative departments

Theme – Miscellaneous

PS Category – Software

Team ID – SIH-UPES-2026-T250

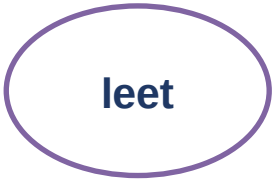
Team Name (Registered on portal) – leet



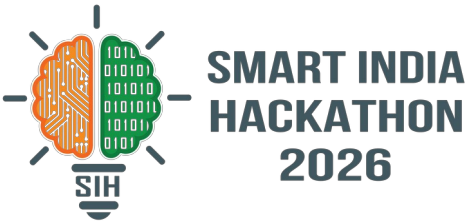
Organisation: Ministry of Home Affairs · National Crime Records Bureau (NCRB)

Separate the trust. Verify before release. Record every access.

Standalone, fully on-premise · no dependency on any external system



PRAMAAN — SECURE EVIDENCE VAULT



Proposed Solution (Idea / Prototype) | How it addresses the problem | Innovation and uniqueness of the solution

TODAY — how a case file is actually held

Scattered
Paper registers and a shared drive per station. No single index across a case.

Co-located
Files, database and keys on one machine. One breach exposes the whole archive.

Unprovable
No way to show a document was never altered after it was filed.

Unaccountable
No reliable record of who opened which file, from where, and when.

PRAMAAN — an end-to-end evidence system: what it does

**MFA + SESSION CONTROL**
A time-based second factor at login, on top of the password.
The session token is verified on every single request, and re-checked before sensitive actions.

**MAGIC-BYTE FILE CHECKS**
The real file type is read from the bytes themselves, never from the filename or the browser.
An executable renamed to .pdf is rejected at upload.

**OCR — DOCUMENT DIGITISATION**
Scanned FIRs and charge sheets become searchable text, entirely on-premise.
Devanagari, Tamil, Telugu, Bengali and Gujarati; low-confidence pages flagged for review.

**CASE-SCOPED ACCESS**
Six roles, plus membership of the specific case, checked on every request.
A case you are not assigned to returns 404, not 403 — its existence is never confirmed.

**DIGITAL SIGNATURES**
An officer signs a document cryptographically to record approval.
Any later modification makes that signature fail verification, visibly.

**RECIPIENT-BOUND SHARING**
Time-limited, revocable access for a named recipient — not an open link.
Every access is recorded against the document it opened.

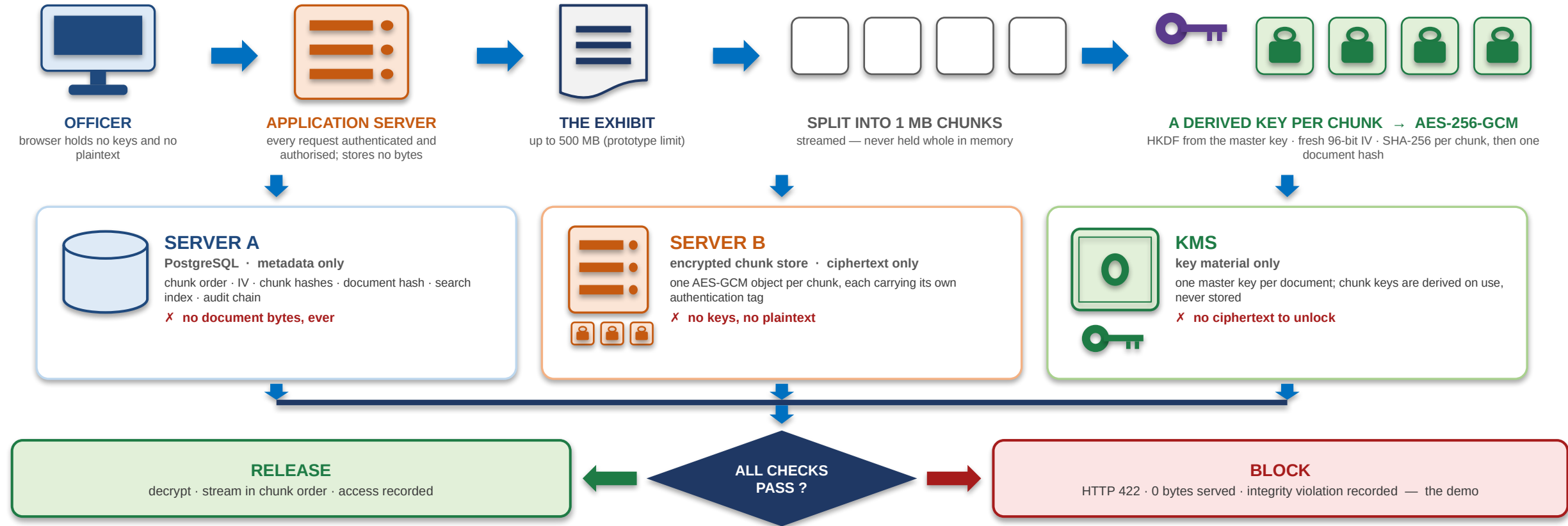
**SEARCH ACROSS A CASE**
Filenames, tags, document type, dates and digitised text, in one query.
Results are always filtered to what that officer is allowed to see.

**TAMPER-EVIDENT AUDIT TRAIL**
Every login, upload, download, signature and share is recorded.
Each record is chained to the one before it, so a retroactive edit fails verification.

One rule holds all of it together: evidence is never released if its integrity cannot be verified.

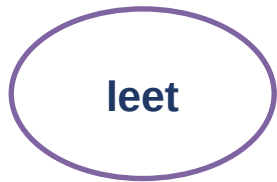
Technologies to be used | Methodology and process for implementation (Flow Charts / Images / working prototype)

SECURITY ARCHITECTURE — one document, end to end

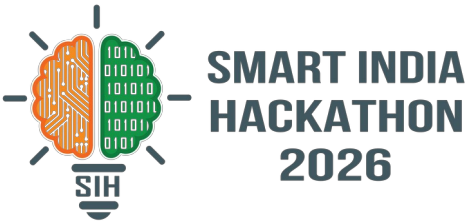


Nothing is streamed before every chunk hash, every authentication tag and the document hash have passed.

React SPA · Flask REST API · PostgreSQL · encrypted chunk store · key management service · Tesseract OCR | AES-256-GCM · HKDF-SHA256 · SHA-256 · Ed25519 · bcrypt · TOTP · JWT

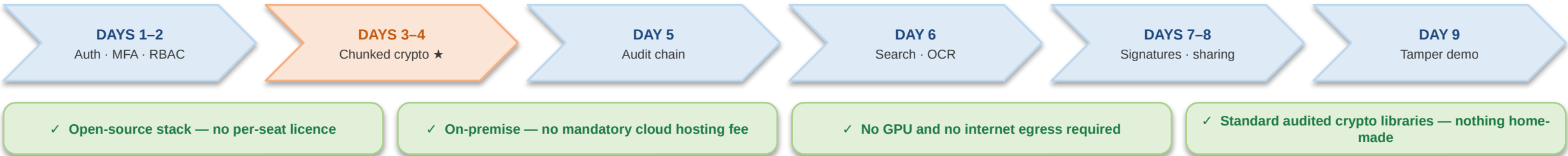


FEASIBILITY AND VIABILITY

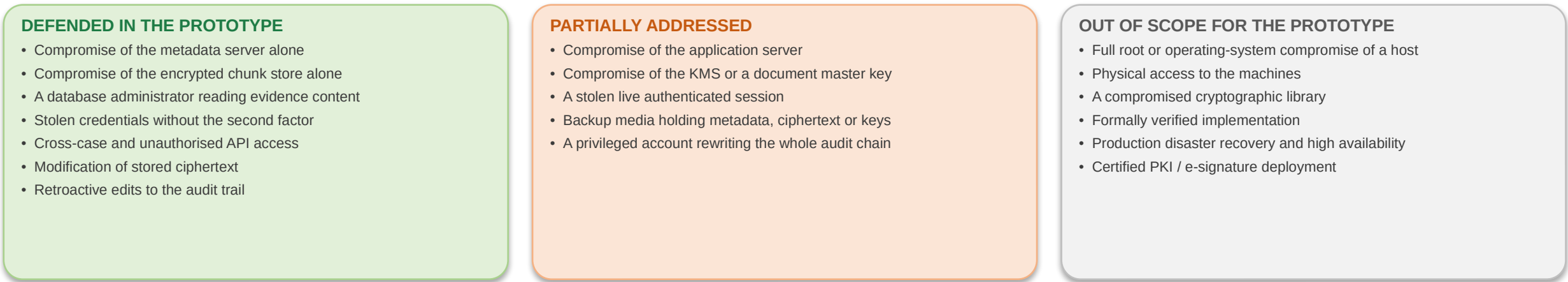


Analysis of the feasibility of the idea | Potential challenges and risks | Strategies for overcoming these challenges

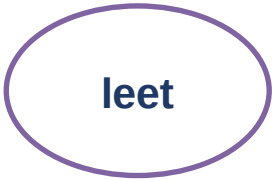
FEASIBILITY — a 9-day build on commodity hardware, with no external system dependency



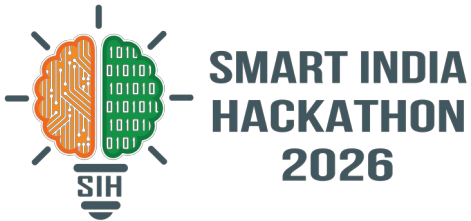
THREAT MODEL — what the prototype defends against, and what it does not



PRAMAAN does not claim compromise is impossible. It limits the impact of partial compromise, and refuses to release evidence it cannot verify.



IMPACT AND BENEFITS



Potential impact on the target audience | Benefits of the solution (social, economic, environmental, etc.)

WHO IT CHANGES, AND HOW

POLICE & INVESTIGATORS

One indexed, encrypted case file replaces station-level registers and shared drives.

COURTS & PROSECUTORS

Receive an exhibit through a recipient-bound, time-limited share, with every access recorded.

FORENSIC LABS

Sign a report cryptographically; any later modification makes that signature fail verification.

AUDITORS & OVERSIGHT

Recompute the audit chain on demand; verification names the first event that fails.

EVIDENCE CUSTODIANS

A verifiable record of who accessed which document, from where, and when.

BENEFITS

SECURITY

- Partial compromise of one storage domain does not yield a readable document.
- Tampering is detected before evidence is released, not after it is relied on.

OPERATIONAL & ECONOMIC

- Open-source stack, no per-seat licence; runs on hardware departments already own.
- On-premise deployment avoids mandatory cloud hosting fees.

ACCOUNTABILITY

- Every upload, access, download and share leaves a hash-chained record.
- Verification is on demand and names the first event that fails.

SOCIAL

- Chain of custody becomes verifiable rather than asserted.
- Case material stays inside the case boundary it belongs to.

WHAT WE WILL MEASURE — stated as targets; figures reported from the prototype, not claimed now

Blast radius of a single compromised host

TARGET Neither storage server on its own yields a readable document.

METHOD Shown by inspection during the demo — the chunk store holds ciphertext only.

Response to an integrity failure

TARGET 0 bytes served, HTTP 422, and an audit event recorded.

METHOD Measured directly on the tampered-chunk demo.

Retrieval and verification time

TARGET To be benchmarked at 10 MB, 100 MB and 500 MB.

METHOD Upload, encryption, verification and total retrieval time recorded separately.

Details / Links of the reference and research work

CRYPTOGRAPHIC STANDARDS WE IMPLEMENT

NIST SP 800-38D

AES-GCM mode, IV construction and tag length — our per-chunk cipher. nvlpubs.nist.gov

RFC 5869 — HKDF

Extract-and-expand key derivation; the basis of our per-chunk keys. rfc-editor.org/rfc/rfc5869

RFC 8032 — Ed25519

Deterministic EdDSA signatures; no per-signature nonce to reuse. rfc-editor.org/rfc/rfc8032

RFC 6238 — TOTP

Time-based one-time passwords for the second factor. rfc-editor.org/rfc/rfc6238

NIST SP 800-57 Part 1 Rev.5

Key-management lifecycle — generation, storage, rotation, destruction.

SECURITY ENGINEERING REFERENCES

OWASP ASVS 4.0

The verification checklist our access-control and crypto-storage requirements map to. owasp.org

OWASP Top 10 (2021)

Broken access control and cryptographic failures drove the 404-not-403 scoping rule.

NIST SP 800-92

Log management guidance behind the audit event schema and retention design.

Saltzer & Schroeder (1975)

Least privilege and complete mediation — why authorisation is re-checked per request.

Threat-model sources

Each threat on slide 4 traces to one of the above rather than to intuition.

TECHNOLOGY & PRIOR ART STUDIED

pyca/cryptography

AESGCM, HKDF and Ed25519 primitives — audited implementations, no custom crypto. cryptography.io

PostgreSQL 16

Full-text search, GIN indexes and transaction-scoped advisory locks. postgresql.org/docs

Tesseract OCR + Indic tessdata

Fully offline OCR with Devanagari, Tamil, Telugu, Bengali and Gujarati packs.

MinIO · HashiCorp Vault

Studied as production swap-ins behind our chunk-store and KMS interfaces.

Ollama · sentence-transformers

Studied for the future on-premise AI layer — not part of the core system.

HOW THE RESEARCH SHAPED THE BUILD

OUR OWN DESIGN RECORD

- Eleven feature plans plus architecture, security, API and cross-cutting edge-case documents.
- Every cryptographic and access-control decision was written down and threat-modelled before implementation.

WHAT THE READING CHANGED

- SP 800-38D → per-chunk HKDF keys instead of one key per file, so an IV cannot repeat under a key.
- OWASP ASVS → 404 instead of 403 on case-scoped resources, so existence is never confirmed.
- NIST SP 800-92 → audit events carry actor, action, case, document and result, not just a message.

FUTURE SCOPE — AI OUTSIDE THE EVIDENCE BOUNDARY

- Context Retrieval — semantic search over a read-only derived index, filtered to cases the officer can already access.
- Document Summarisation — a local model drafts summaries on-premise; no evidence leaves the network.
- Secure Session Playground — the ephemeral sandbox summarisation runs in, wiped on close, nothing retained unless saved.
- The AI layer reads a derived copy and can never modify original evidence.